



**Università
di Catania**

Internet Security:
Improper Platform Usage
Scenario: Attacco

Studente: Antonio Pistone

Matricola: 1000050018

Sommario

1 Introduzione	3
2 WebView Demo	4
2.1 Descrizione dell'applicazione	4
2.2 Attacco	5
2.3 Fix.....	6
3 Clipboard Demo	7
3.1 Descrizione dell'applicazione	7
3.2 Attacco	7
3.3 Fix.....	9
4 Calcolatrice Demo	9
4.1 Descrizione dell'applicazione	9
4.1 Attacco	10
4.2 Fix.....	11
5 Riferimenti	12

1 Introduzione

Improper Platform Usage (in italiano: uso improprio della piattaforma) è una categoria di vulnerabilità dei sistemi mobile identificata dall'**OWASP (Open Web Application Security Project)**¹. Con il termine Improper Platform Usage, L'OWASP si riferisce ad errori nello sfruttamento delle funzionalità offerte dalla piattaforma mobile come Android o iOS, in particolare quando:

- Lo sviluppatore non utilizza correttamente le librerie o i meccanismi di sicurezza forniti dal sistema operativo.
- Viene ignorata o mal interpretata la documentazione ufficiale o le linee guida di sicurezza.
- L'applicazione non segue le pratiche consigliate dal produttore della piattaforma.

La rubrica "Top Ten" di OWASP riconosciuta a livello globale, ha posizionato tale categoria di vulnerabilità al **primo posto** nella classifica del 2016 delle 10 vulnerabilità più critiche per le applicazioni mobile.

¹ **Open Web Application Security Project (OWASP)** = è un progetto open-source che ha lo scopo di formulare linee guida, strumenti e metodologie per migliorare la sicurezza delle applicazioni informatiche.

2 WebView Demo

2.1 Descrizione dell'applicazione

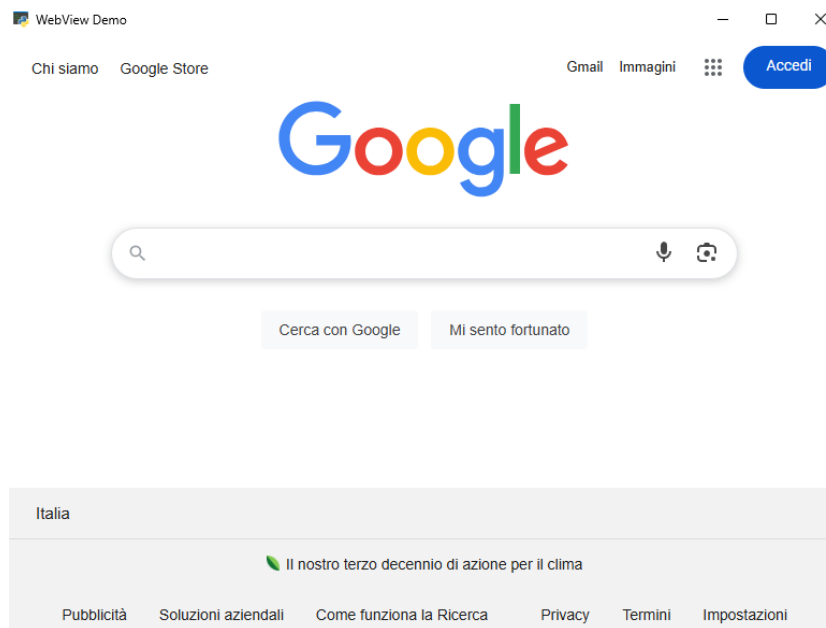
Per dimostrare l'impatto di come gli hacker possano abusare delle funzionalità della piattaforma mobile per sfruttare i difetti di un'app, si è proceduto alla creazione di un'applicazione appositamente vulnerabile chiamata WebViewDemo. L'applicazione è molto semplice e minimale, consiste nella creazione di una **WebView**, ovvero un componente dei sistemi mobile che permette alle app di visualizzare contenuti web all'interno della propria interfaccia, senza la necessità di aprire un browser esterno. Molte app popolari usano le WebView per integrare contenuti web direttamente nell'app e poter dunque dare la possibilità all'utente di aprire link esterni. Per quanto concerne la realizzazione dell'app si è deciso di svilupparla in linguaggio python. Di seguito è riportato il codice sorgente.

```
import webview

url = input("Inserisci un URL da aprire nella WebView: ")
webview.create_window("WebView Demo", url)
webview.start()
```

Una volta eseguito il programma, otterremo il seguente output:

```
PS C:\Users\Antonio\Desktop\Progetto ITS> & C:/Users/Antonio/AppData/Local/Programs/Python/Python39-64/Python.exe C:/Users/Antonio/Desktop/Progetto ITS/es.py
Inserisci un URL da aprire nella WebView: https://www.google.com/
```

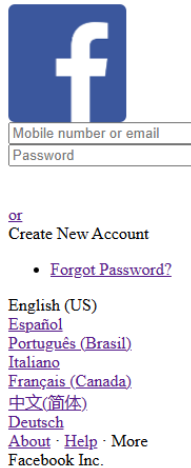


2.2 Attacco

Questo piccolo programma presenta in realtà numerosi problemi e pessime scelte di progettazione dal punto di vista della sicurezza. **Il problema principale è che l'input non attendibile viene accettato e non viene sanificato prima di essere utilizzato.** In questa applicazione non ci sono limiti o controlli sul valore di input, ciò significa che un attaccante potrebbe per esempio creare un payload dannoso e passarlo alla vittima in modo tale da indurlo in siti web non sicuri. Per simulare un comportamento simile è stato creato un finto link che porta ad una pagina di login di Facebook. Pertanto inserendo il seguente indirizzo:

```
PS C:\Users\Antonio\Desktop\Progetto ITS> & C:/Users/Antonio/AppData/Local/Programs/Python/Python313/python.exe "c:/Users/Antonio/Desktop/Progetto ITS/es.py"  
Inserisci un URL da aprire nella WebView: C:\Users\Antonio\Desktop\Progetto ITS\Facebook_Login.html
```

L'utente verrà immediatamente reindirizzato alla seguente pagina:



The image shows a screenshot of the Facebook login interface. At the top is the Facebook 'f' logo. Below it are two input fields: 'Mobile number or email' and 'Password'. To the right of these fields is a 'Log In' button. Below the input fields, there is a link for 'Forgot Password?'. At the bottom, there are links for 'English (US)', 'Español', 'Português (Brasil)', 'Italiano', 'Français (Canada)', and '中文(简体)', followed by 'Deutsch', 'About · Help · More', and 'Facebook Inc.'.

Se la vittima inserisse i propri dati, l'attaccante riuscirebbe ad appropriarsene.

2.3 Fix

Analizzando l'esempio visto in precedenza, ci siamo potuti accorgere dei numerosi aspetti da considerare quando si vuole proteggere un'app mobile. Da questa demo si possono trarre alcuni spunti interessanti:

- È sempre importante **comprendere le classi e le funzionalità utilizzate nell'app.**
- **Convalidare e sanificare sempre l'input**, indipendentemente dal fatto che provenga da un utente, da un database o da qualsiasi altro luogo.

3 Clipboard Demo

3.1 Descrizione dell'applicazione

In questa demo andremo a vedere una tipologia di attacco che si effettua alla **clipboard** dei dispositivi mobile. La clipboard è uno spazio temporaneo di memoria del sistema operativo usato per copiare e incollare dati tra applicazioni. Ogni qualvolta un utente copia un determinato tipo di file (testo, immagine ecc), questo file viene salvato temporaneamente nella clipboard.

3.2 Attacco

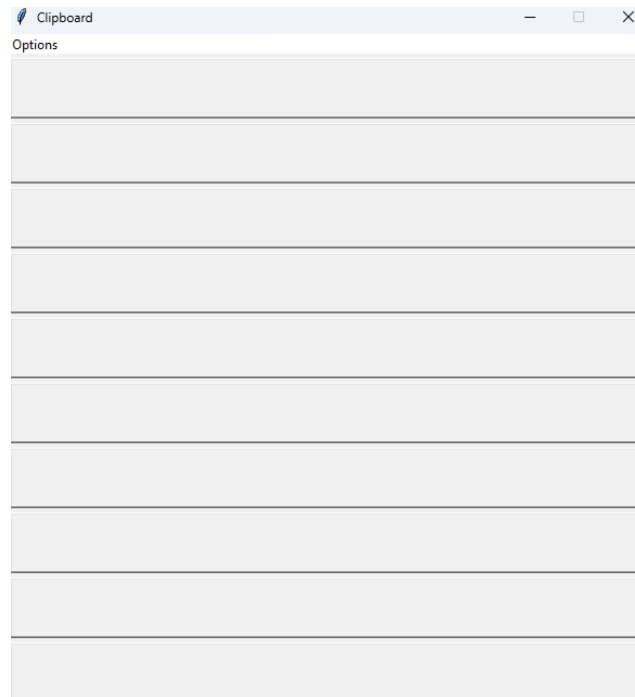
Fino alla versione 10 di Android e alla versione 13 di iOS tutte le app che erano in esecuzione in background sul dispositivo potevano avere accesso al contenuto della clipboard. La lettura non autorizzata del contenuto degli appunti della clipboard da parte di app malevole o indiscrete, può avere impatti molto seri sia sulla **privacy** che sulla **sicurezza** degli utenti. Un utente malintenzionato potrebbe:

- **Intercettare nomi utente, password, o token di autenticazione** (es. copiate da un password manager)
- **Effettuare un tracciamento comportamentale.**

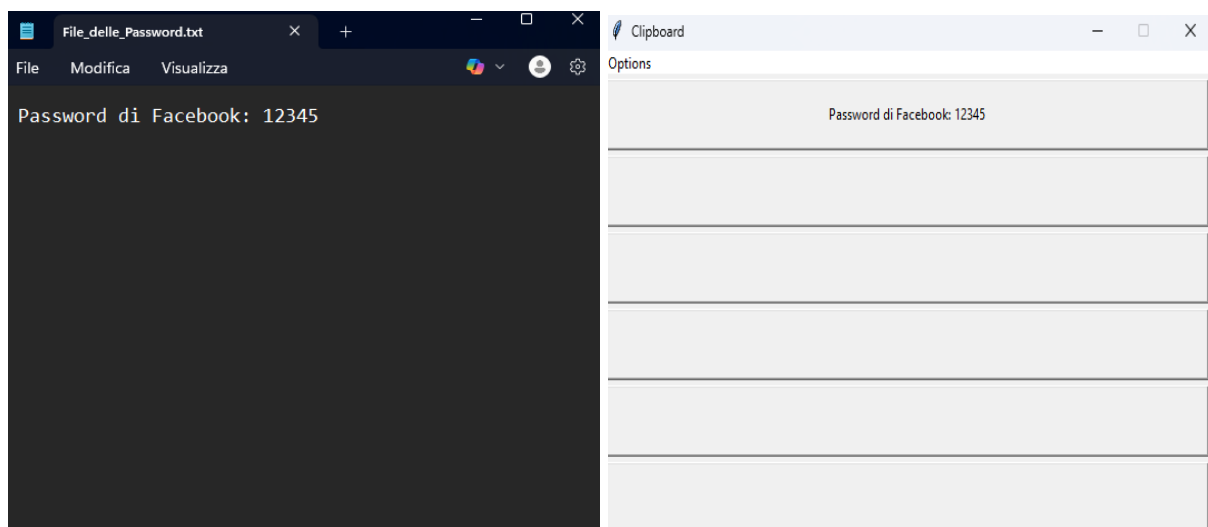
Per eseguire questo tipo di attacco è stato realizzato un codice in linguaggio python. Al momento del suo avvio, esso controlla immediatamente il contenuto della clipboard e lo stampa a schermo, inoltre il programma è costruito per essere in grado di rimanere in ascolto ed intercettare ogni aggiornamento che la clipboard subisce.

[Clipboard.py](#)

L'output che il programma restituisce è il seguente:



Da questo momento in poi ogni volta che l'utente copia un testo, esso comparirà in chiaro.



3.3 Fix

La vulnerabilità legata all'accesso alla clipboard da parte di app in background è stata affrontata e mitigata:

- Da Google con l'aggiornamento di Android 12.
- Da Apple con l'aggiornamento di iOS 14.

Le app dei dispositivi che supportano queste versioni o versioni più recenti **non possono più accedere alla clipboard in background, bensì necessitano obbligatoriamente di essere in primo piano.** Inoltre sia Google e sia Apple hanno introdotto un'ulteriore misura restrittiva che consiste nell'invio di un avviso non appena una qualsiasi app accede al contenuto della clipboard.

4 Calcolatrice Demo

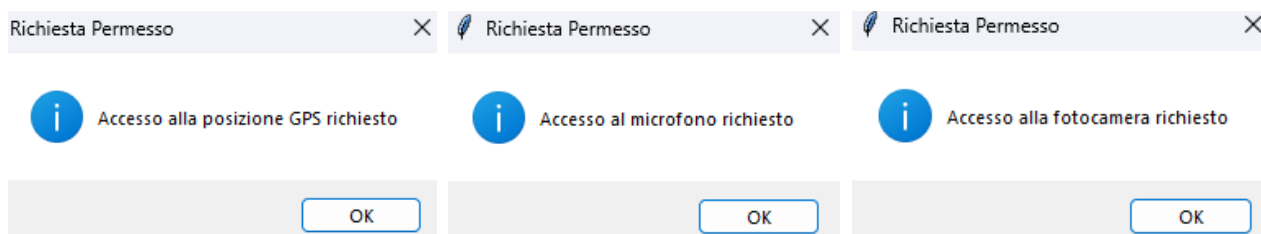
4.1 Descrizione dell'applicazione

In quest'ultima demo andremo a vedere un altro esempio di applicazioni mobile che fa un uso improprio della piattaforma. Per tale scopo è stata realizzata una semplice applicazione in linguaggio python che simula il comportamento di una calcolatrice. L'applicazione è progettata per richiedere l'accesso a vari servizi offerti dallo smartphone come: l'utilizzo della telecamera, l'utilizzo del microfono, l'utilizzo del gps ecc. **Tutti questi elementi non sono affatto indispensabili per il corretto utilizzo della nostra applicazione, pertanto un utente malevolo potrebbe distribuire un'applicazione simile per poi abusare dei permessi concessi dall'utente.**

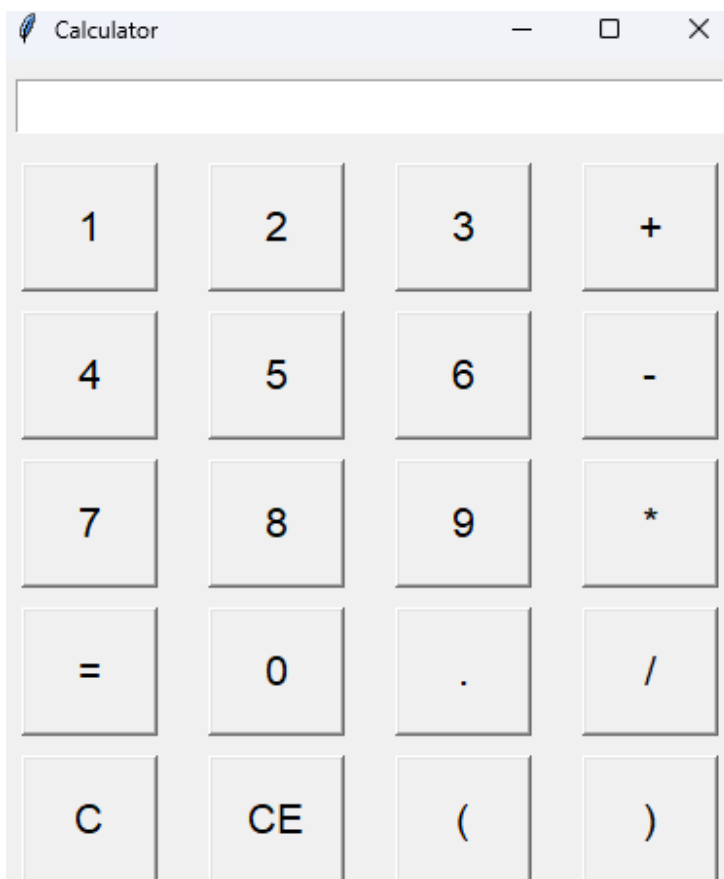
[Calcolatrice.py](#)

4.1 Attacco

Una volta avviata l'applicazione, cominceranno a comparire a schermo i vari avvisi che chiedono all'utente di poter usufruire dei servizi dello smartphone.



Una volta accettati tutti i permessi, l'applicazione funzionerà come una normale calcolatrice.



4.2 Fix

Nel caso visto in precedenza, è stato simulato un comportamento abusivo in cui l'app, pur svolgendo una funzione semplice, richiede numerosi permessi sensibili. Questo comportamento può essere pericoloso, poiché l'utente potrebbe inconsapevolmente fornire accesso a microfono, fotocamera o posizione, che l'app può poi sfruttare per fini malevoli. Alcune contromisure contro attacchi del genere sono:

- Concedere solo i permessi strettamente necessari.
- Disinstallare app sospette o che mostrano comportamenti anomali.

5 Riferimenti

1. OWASP M1: Improper Platform Usage

<https://owasp.org/www-project-mobile-top-10/2016-risks/m1-improper-platform-usage>

2. Impact of Improper Platform Usage on Mobile Applications

<https://www.appsealing.com/improper-platform-usage/>

3. Mobile AppSec: Understanding Improper Mobile Platform Usage and Client Code Quality

<https://medium.com/walmartglobaltech/mobile-appsec-understanding-improper-mobile-platform-usage-and-client-code-quality-589124ed39b0>

4. TikTok legge in continuazione i vostri appunti su iPhone, lo rivela iOS 14

<https://www.ilfattoquotidiano.it/2020/06/29/tiktok-legge-in-continuazione-i-vostri-appunti-su-iphone-lo-rivela-ios-14/5851547/>

5. How to create your own clipboard manager using python and Tkinter

<https://medium.com/@prashantgupta24/how-to-create-your-own-clipboard-manager-using-python-and-tkinter-e693aa27fffc>

6. Codice sorgente clipboard

<https://github.com/prashantgupta24/clipboard-manager/blob/master/src/clippy.py>

7. Python Programming — Projects (GUI Based Basic Calculator)

<https://medium.com/@DataEngineeer/python-programming-projects-gui-based-basic-calculator-3bc3c982aad1>